

Desiree aba Mensah

Mobile: + 15714267775 | desireemensah.aba@gmail.com

PROFESSIONAL SUMMARY

Results-driven Risk Management and Cybersecurity Specialist with expertise in security frameworks, compliance, and risk assessment. Skilled in implementing risk strategies using NIST RMF, ISO 27005, OCTAVE, FAIR, and COBIT, and ensuring regulatory compliance with GDPR, ISO 27001, NIST 800-53, PCI DSS, HIPAA, and SOC 2. Proficient in cybersecurity tools, including SIEM solutions, vulnerability management, firewalls, IDS/IPS, endpoint protection, encryption, IAM, and zero-trust architectures. Experienced in third-party risk management, vendor security assessments, penetration testing reviews, and business continuity planning. Certified in CompTIA Security+ and Security A+, with hands-on experience in security auditing, incident response, and compliance documentation such as SSP, SAR, POA&M, and ATO. Strong collaborator with cross-functional teams, regulatory bodies, and industry experts to mitigate risks and enhance cybersecurity resilience.

TECHNICAL SKILLS

Cyber Risk Assessment | Actuarial Methods | SQL | Python | R | Data Visualization (Tableau, Power BI) | NIST Guidelines Publications | AWS | Microsoft Azure | Google Cloud Platform (GCP) | SIEM (Splunk, QRadar) | GRC Tools (ServiceNow, One Trust) | Vulnerability Management (Nessus, Qualys) | Certification and Accreditation (C&A) | Assessment and Authorization (A&A) | HIPAA & PRIVACY ACT training | PCI DSS | ISO 27001 | IT Security Compliance | Vulnerability Assessment | Net| work Vulnerability Scanning | Information Assurance | System Risk Assessment | SOX Section 404 | CCPA | GDPR | PCI-DSS | HITRUST, FedRAMP | System Development Life Cycle | Nessus Vulnerability Scanner | ACAS | HBSS | SCAP | Splunk | SharePoint | Nexpose | LAN | WAN | ISO 31000 | ISO 27001/2| NIST CSF | NIST 800 Series| COBIT | ITIL | NIST SP 800-53 | SP 800-53A | SP 800-37 | NIST SP 800-171 | FIPS | FISMA | FedRAMP | Risk Management Framework (RMF) | FIPS-199 | PTA | PIA | SSP | CP | SAR | POA&M | ATO | ISA | MOU/A | IDS | IPS | Windows.

CERTIFICATIONS:

- Certified Information Systems Auditor (CISA) - 2020
- Security+ Certified - 2019
- CompTIA Security+

PROFESSIONAL TRAINING:

- Information Assurance Awareness Training 2016
- ISACA GRC Conference – 2022
- ServiceNow Risk Work-shop - 2023
- Enhancing Your Risk-Based Audit Skills Training 2020
- Information Systems Security Training 2015
- SANS Security Awareness: Managing Human Risk Summit - 2022

PROFESSIONAL EXPERIENCE

GOVERNANCE, RISK AND COMPLIANCE LEAD

AGO WORLDWIDE CONSULTING, SEVERN MD

AUGUST 2019 to Present

- Presented TPRM reports to senior management, boards, and external stakeholders, including the OCC. Communicated complex issues clearly and credibly.
- Lead and drive cybersecurity risk management program. Making sure risk is identified, assessed, reported, and monitored. Experienced leveraging NIST and ISO frameworks.
- Manage Third-Party Risk Program (TPRM) for over 1000 vendors. Expert in using excel spreadsheet or tools such as One trust, Audit board, Prevalent, Service Now and Process Unity.

- Develop and manage Annual Security Review processes for compliance with cybersecurity and privacy regulations.
- Oversee control standards (PCI DSS, COBIT, ISO27001, NIST 800:53, HITRUST, GDPR, CCPA) and control testing strategies.
- Develop, manage and improve TPRM Program and framework.
- Provide security posture recommendations for new enterprise use cases.
- Train new security analysts and interns in cybersecurity and risk management.
- Assist in providing enterprise-wide dashboard reports and trend analysis for 3rd party risk monitoring activities.
- Support business owners in risk management activities and decision-making processes.
- Conduct information security risk assessments and assist in remediation efforts.
- Maintain **PCI DSS Compliance** and support AOC process management.
- Develop, implement, and improve policies and procures.

THIRD-PARTY RISK MANAGEMENT ANALYST

GEEK VIEW TEK SOLUTIONS, FREDERICK, MD

APRIL 2018 – JUNE 2019

- Provide support to the 3rd Party Risk Management team and business units.
- Executed TPRM strategies that supported the bank's overall risk management framework and business objectives.
- Lead the risk management program and conduct security risk assessments.
- Manage compliance programs for certifications such as ISO 27001/27002, NIST, SOC2, and PCI-DSS.
- Conduct security risk assessments of 3rd parties and coordinate responses to information security incidents.
- Provide security consulting and awareness education to business teams.
- Coordinate assessments and audit initiatives set forth by the CISO and business lines.
- Perform enterprise governance, risk assessments, and reporting.
- Implemented continuous monitoring mechanisms for third-party vendors to assess their security posture regularly and detect any emerging risks or vulnerabilities in real-time.
- Conducted periodic security reviews and audits of vendor security practices, ensuring ongoing compliance and identifying new or existing risks that need to be mitigated.
- Ensured vendors applied patch management, incident response plans, and access controls to maintain a strong security stance, including timely updates and established procedures for handling security breaches.
- Collaborated with vendors to investigate and mitigate security incidents promptly, ensuring that the organization is informed and involved in the incident response when a breach or security event occurs.

INFORMATION SECURITY ANALYST

JHC TECHNOLOGY, INC., NATIONAL HARBOR, MD

OCTOBER 2016 - MARCH 2018

- Perform enterprise Audit conducting, Reviews, Reports, vendor risk assessment, and Security Control Assessment.
- Formulate recommendations regarding control deficiencies and system ineffectiveness.
- Support reviewing Intrusion Detection Systems (IDS), Intrusion Prevention Systems (IPS), and Security Information Event Management (SIEM) Systems.
- Prepare or review audit documents, work papers, audit reports, and presentations.
- Conduct IT control assessments and support IT audit risk assessments.
- Develop and manage contract/programs security documentation.
- Coordinate and participate in regular internal and external audits.
- Monitor and analyze security threats, vulnerabilities, and incidents to protect IT infrastructure.
- Implement and enforce security policies, standards, and best practices to ensure compliance.
- Conduct risk assessments and security audits to identify and mitigate potential security gaps.
- Manage IAM, access controls, and RBAC to enforce the principle of least privilege.

EDUCATION:

- Bachelor of Science (BS), Computer Science, CENTRAL UNIVERSITY, GHANA- 2015

- High school diploma, Walton High School, Bronx, NY - 2010